

보안 스터디

2 차시 주제: ATM Skimming

ATM Skimming

목차

1. 사전 조사	2
1) 하드웨어 해킹의 개념	2
(1) 하드웨어 해킹의 정의	2
(2) 소프트웨어 해킹과의 차이점	2
(3) 물리적 공격과 정보 보안의 관계	2
2) ATM의 기본 구조와 동작 원리	3
(1) ATM의 기본 구성 요소	3
(2) 마그네틱 카드의 데이터 저장 구조	3
(3) 카드 정보가 읽히는 과정	4
(4) PIN 입력 및 인증 과정	5
2. 본 조사	7
1) ATM Skimming	7
(1) ATM Skimming의 개요 및 동작 원리	7
(2) 정보 탈취 방식 및 공격 시나리오	8
(3) ATM Skimming 실제 피해 사례 및 대응 방안	8
(4) ATM Skimming 총정리	9
3. 참고 자료	10

1. 사전 조사

1) 하드웨어 해킹의 개념

(1) 하드웨어 해킹의 정의

- 전자 부품을 물리적으로 조작, 분석 또는 수정하여 시스템에 더 깊이 접근하거나 취약점을 발견, 보호장치를 우회하는 것

(2) 소프트웨어 해킹과의 차이점

- 소프트웨어 해킹
 - 공격 대상: 응용 프로그램, 운영체제, 소프트웨어 등
 - 공격 방식: SQL Injection, DDoS 등
 - 대응 방식: 보안 패치, 취약점 스캔, 방화벽 등
- 하드웨어 해킹
 - 공격 대상: 집적 회로¹, 프로세서, 메모리 모듈, 통신 인터페이스 등
 - 공격 방식: Side-Channel Attacksⁱ, Fault Injection Attacksⁱⁱ, Physical Tamperingⁱⁱⁱ 등
 - 대응 방식: Tamper Resistance^{iv}, Secure Hardware Design^v, Firmware Security^{vi} 등

(3) 물리적 공격과 정보 보안의 관계

- 물리적 접근은 정보 보안의 핵심 요소인 기밀성을 직접적으로 위협할 수 있음
- 해커나 범죄자는 시스템 내부 소프트웨어를 해킹하지 않더라도, 물리적 장치를 이용해 정보 자산을 탈취할 수 있음

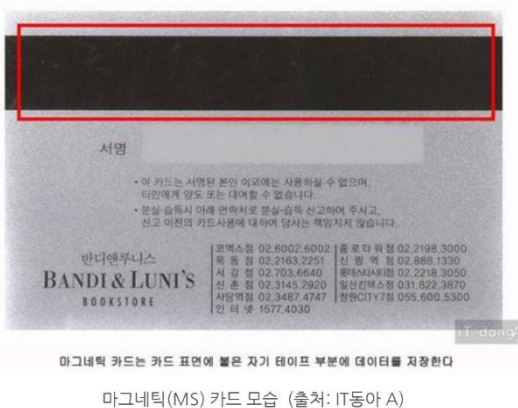
¹ 집적 회로: 수많은 전자 부품을 아주 작은 칩 하나 안에 모아 놓은 것

2) ATM²의 기본 구조와 동작 원리

(1) ATM의 기본 구성 요소

- 처리 및 제어 장치
 - 중앙 처리 장치(CPU)
 - 암호화 칩
- 카드 입력 및 인증 장치
 - 마그네틱 카드 리더기
 - 스마트 카드 리더기
 - RFID/NFC 리더기
- 사용자 입력 장치
 - 숫자 키패드
 - 기능키
 - 터치 스크린
- 출력 장치
 - 화면
 - 프린터
- 현금 보관 장치
 - 금고

(2) 마그네틱 카드의 데이터 저장 구조



- 마그네틱 카드란
 - MS(Magnetic Strip)라 불리는 자기 테이프가 들어간 카드

² ATM: (Automated Teller Machine, 현금 자동 입출금기) 은행을 대신하여 입출금이나 송금, eerl
역무를 편리하게 처리할 수 있도록 설치되는 기기

Magnetic Stripe Encoding - Financial Transaction Cards

0.223"	Track		Recording Density (bits per inch)	Character Configuration (including parity bit)	Information Content (including control characters)
0.110"	1	IATA	210	7 bits per character	79 alphanumeric characters
0.110"	2	ABA	75	5 bits per character	40 numeric characters
0.110"	3	THRIFT	210	5 bits per character	107 numeric characters

마그네틱(MS) 카드 구조 (출처: MAGTEK)

- 마그네틱 카드의 데이터 구조(구성 정보)
 - Track1: 79 자리까지의 영문자 및 숫자
 - 주로 이름 등의 영문자 정보를 저장하는데 사용
 - Track2: 40 자리까지의 숫자
 - 주로 신용카드나 체크카드의 결제 정보를 저장하는데 사용
 - Track3: 107 자리까지의 숫자
 - 주로 계좌 정보나 추가 금융 데이터를 저장하기 위해 사용되었으나, 현재는 거의 사용되지 않음

(3) 카드 정보가 읽히는 과정

- 정보 기록 및 판독 방법
 - 정보 기록 방법
 - 전류를 흘려 발생한 자기장에 의해 마그네틱 띠가 자화되는 원리를 이용하여 정보를 기록함
 - 판독 방법
 - 마그네틱 띠의 자기 방향 변화에 따라 자기장이 변하고, 이로 인해 발생하는 유도전압을 통해 정보를 판독함

(4) PIN³ 입력 및 인증 과정

- ① PIN 입력 및 암호화
 - PIN은 암호화된 PIN 패드(EPP)⁴에서 입력됨
 - 입력 즉시 내부 대칭 키를 사용하여 PIN을 암호화하며 평문 PIN은 장치 외부로 전송되지 않음
- ② PIN 블록 생성
 - 암호화된 PIN은 계좌 번호와 결합되어 ISO 9564⁵ 형식의 PIN 블록으로 생성됨
 - PIN 블록은 암호화된 상태로 유지되며, 하위 시스템에도 평문 PIN은 노출되지 않음
- ③ ATM 내부 거래 처리
 - ATM은 카드 정보, 거래 유형, 금액, 단말기 ID 등의 거래 데이터를 수집함
 - 카드가 EMV⁶ 칩 카드이고 오프라인 PIN을 사용하는 경우, 키와 암호화 검사를 통해 로컬에서 오프라인 PIN 인증이 수행될 수 있음
- ④ 호스트 시스템으로 전송
 - ATM은 ISO 8583⁷ 형식의 인증 요청 메시지를 생성하여 은행 호스트 또는 결제 네트워크로 전송함
 - 이 과정은 VPN, TLS 등의 암호화된 통신 채널을 통해 이루어지며, 전송 중 기밀성과 무결성이 보장됨
- ⑤ 발급사 측 PIN 검증
 - 발급 은행은 HSM⁸을 사용하여 PIN 블록을 검증함

³ PIN: Personal Identification Number, 개인 식별 번호, 개인의 신원을 확인하기 위한 숫자 코드

⁴ EPP: Encrypting PIN Pad, PIN을 입력 받는 동시에 내부에서 암호화하여 평문 노출을 방지하는 보안 키패드

⁵ ISO 9564: PIN 처리 및 보안 방식에 대한 국제 표준

⁶ EMV: Europay, Mastercard, Visa 세 결제 네트워크가 만든 국제 결제 보안 표준

⁷ ISO 8583: 카드 결제 및 ATM 거래 메시지 형식을 정의한 국제 표준

⁸ HSM: Hardware Security Module, 암호 키를 안전하게 저장하고 암호 연산을 수행하는 전용 보안 장치

- 온라인 PIN 의 경우 저장된 PIN 검증 값과 비교하며, 이 과정에서도 평문 PIN 은 노출되지 않음
- ⑥ 승인 및 응답
- 발급 은행은 승인 여부를 결정하고 응답 코드를 반환함
 - ATM 은 해당 응답을 수신하여 출금 처리 또는 거래 거절을 수행함
- ⑦ 보안 관리
- 모든 PIN 암호화는 HSM 과 엄격한 키 관리 절차에 따라 운영됨
 - 거래 로그는 저장되지만, PIN 은 평문으로 기록되지 않음
 - 이상 거래가 감지될 경우 추가 인증 또는 거래 차단이 이루어짐

2. 본 조사

1) ATM Skimming

(1) ATM Skimming의 개요 및 동작 원리

- Skimming
 - 카드, 계좌번호, 유효기간, 개인 식별번호(PIN) 등 신용, 현금 인출 카드의 정보를 스키머⁹를 이용해 취득, 복제하는 범죄 행위
 - 스키머를 이용해 카드 뒷면의 마그네틱 띠에 기록된 카드 데이터를 읽어 메모리에 저장하고, 저장된 데이터를 이용해 복제 카드를 만들어 내는 원리
- ATM Skimming: Skimming 기법이 ATM을 대상으로 수행되는 범죄 행위
- ATM 카드 삽입구에 스키머를 부착하여 정보를 복제하고, 추가 장치를 통해 PIN을 확보하여 부정 인출에 이용함
- Skimmer 구분

구분	특징
메모리형 스키머	● 스키머의 내장 메모리 또는 SD 카드에 스키밍된 카드 정보를 저장 ● 스키밍 종료 후 PC/케이블을 이용해 카드 정보 추출
무선 통신형 스키머	● 무선으로 스키밍된 카드 정보를 실시간 전송 ● 셀룰러, Wi-Fi, 블루투스⁹와 같은 통신 방식 활용

카드 정보 처리 방식에 따른 스키머의 구분 (출처: 보안뉴스 ATM 불법 금융정보 유출 방지 위한 '안티스키밍' 전략)

⁹ 스키머(Skimmer): 카드의 마그네틱 띠 정보를 몰래 판독하여 복제 데이터를 수집하는 불법 장치

(2) 정보 탈취 및 공격 시나리오

① 스키머 설치

- 카드 슬롯 입구에 스키머 부착
- 딥 인서트 방식¹⁰으로 내부 삽입
- 외관을 정상 베젤¹¹과 유사하게 제작

② 카드 데이터 수집

- 마그네틱 띠 데이터 판독 및 저장
- 일부 장치는 무선 전송 기능 포함

③ PIN 탈취

- 가짜 PIN 패드 오버레이¹² 설치
- 초소형 카메라 설치

④ 데이터 회수 및 복제

- 장치 회수 후 데이터 추출
- 복제 카드 제작 및 부정 인출

(3) ATM Skimming 실제 피해 사례 및 대응 방안

- ATM Skimming 실제 피해 사례

- 2025 년 미국 플로리다 편의점에서 ATM Skimmer 설치 보고
- 2025 년 호주에서 두명의 루마니아 남성이 Skimming 사기로 기소, 80 만 달러 이상의 피해

¹⁰ 딥 인서트 방식: 카드 삽입구 내부에 얇은 스키머 장치를 삽입하여 외부에서 식별하기 어렵게 만든 스키밍 공격 기법

¹¹ 베젤: 장치의 테두리 부분 또는 입구를 감싸는 외부 프레임

¹² 오버레이: 기존 장치와 겉 모습을 똑같이 만든 가짜 장치를 덮어씌우는 방식

- ATM Skimming 대응 방안
 - 카드 투입구에 스키머 부착을 어렵게 만드는 방지 캡과 적외선 계열의 스키머 감지기 설치
 - 카드 투입구 내부에 스키머 방해 전자파 발생기, 무선 통신형 스키머 대응을 위한 RF 신호 감지기 등 설치
 - 스키머가 감지되었을 경우 경보 발생과 함께 카드 판독기 폐쇄 및 거래 즉시 중단
 - PIN 번호를 입력하기 전에 키패드 가장자리 당겨 진짜 키패드인지 확인하기
 - PIN 번호를 입력할 때 최대한 가리고 입력하기

(4) ATM Skimming 총정리

- ATM Skimming: 마그네틱 카드의 데이터를 불법적으로 읽어 저장하고, 추가적으로 PIN 정보를 탈취하여 복제 카드를 만들어 부정 인출을 수행하는 물리 기반 금융 범죄
- ATM Skimming 공격 원리: ATM 카드 투입구에 스키머를 부착하여 마그네틱 띠의 데이터를 판독하고 저장한 뒤, 가짜 PIN 패드 오버레이 또는 초소형 카메라 등을 통해 PIN 을 확보하여 금융 정보를 얻음
- ATM Skimming 위험성: 카드 정보와 PIN 이 동시에 탈취될 경우 복제 카드 제작이 가능하며, 피해자는 즉각적으로 인지하기 어려움
- 대응 관점: 카드 투입구 및 내부에 스키머 감지 및 방해 장치 설치, 감지 시 거래 중단, 사용자는 키패드 확인과 PIN 가리기 등 예방 중심의 보안 수칙 준수

3. 참고 자료

하드웨어 해킹의 개념

[Exploring Hardware Hacking As A Critical Layer In IoT Security | by Redfox Security |](#)

[Medium](#) (하드웨어 해킹이란)

[Hardware Attacks in Cybersecurity - SearchInform](#) (소프트웨어 해킹과의 차이점에서

하드웨어 해킹 편)

[Physical information security - Wikipedia](#) (물리적 공격과 정보 보안의 관계)

ATM의 기본 구조와 동작 원리

[현금 자동 입출금기 - 오늘의 AI 위키](#) (ATM의 기본 구조)

[마그네틱\(MS\) 카드의 특성과 데이터 구조\(구성 정보\) : 네이버 블로그](#) (마그네틱 카드의

데이터 저장 구조)

[#1. 카드 결제 방식 분석 및 복사 연구\(Magnetic, RFID, IC\) by 라온화이트햇 : 네이버](#)

[블로그](#) (카드 정보가 읽히는 과정)

[What is the back-end process in an ATM when someone is typing a secret code? -](#)

[Quora](#) (PIN 입력 및 인증 과정)

ATM Skimming

[ATM 불법 금융정보 유출 방지 위한 '안티스키밍' 전략](#)(ATM Skimming의 개요 및 동작 원리, ATM Skimming 대응 방안)

[Attacks Against ATMs: Intelligence from the Dark Web > Searchlight Cyber](#) (정보 탈취 및 공격 시나리오)

[Tampa Police Investigate Credit Card Skimmers Found on ATMs | City of Tampa](#) (ATM Skimming 실제 피해 사례 1)

[Two Romanian men charged over NSW card skimming scam that netted more than \\$800K - ABC News](#) (ATM Skimming 실제 피해 사례 2)

i Side-Channel Attacks

Timing Attacks: 계산 시간이 다른 것을 측정해서 비밀 정보를 알아내는 공격 기법

Power Analysis Attacks: 전력 변동의 패턴을 파악해서 암호 키를 추출하는 공격 기법

ii Fault Injection Attacks

Voltage Fault Injection: 전압을 조작함으로써 장치 작동에 결함을 유발하여 예상치 못한 동작을 유발하는 공격 기법 (보안 메커니즘 우회 또는 민감한 정보 추출 가능)

Clock Glitching: 장치의 클럭 신호에 글리치를 주입하여 정상 작동을 방해해 보안 검사를 우회하거나 무단 접근을 허용하도록 하는 공격 기법 (하드웨어의 견고성 약화, 악용 허용)

(a) 클럭 신호: 컴퓨터가 언제 동작해야 하는지 알려주는 박자 신호

(b) 글리치: 아주 짧게 발생하는 비정상적인 신호 오류

Electromagnetic Fault Injection: 전자기 방사선을 이용해 장치 작동에 결함을 유발하여 보안 취약점이나 민감한 정보 유출을 초래하는 공격 기법

iii Physical Tampering

Reverse Engineering: 장치의 물리적 구조를 분해하거나 분석함으로써 내부 메커니즘에 대한 통찰을 얻는 공격 기법

Chip Decapsulation: 칩 회로에서 캡슐화 재료를 제거함으로써 실리콘 다이에 직접 접근하여 탐지나 수정과 같은 침습적 공격을 용이하게 할 수 있도록 하는 공격 기법 (하드웨어 내부 작동 방식을 깊이 파악할 수 있게 하여 정교한 악용을 가능하게 함)

-
- (a) 실리콘 다이: 집적 회로 내부에 있는 실제 반도체 칩 조각, 모든 연산이 이루어지는 핵심 부품임

Component Replacement: 진짜 하드웨어 부품을 악의적인 부품으로 대체하여 백도어나 악성코드를 시스템 내에 삽입하는 공격 기법 (하드웨어의 무결성을 훼손하여 공격자가 무단 통제를 행사하거나 민감한 데이터를 추출할 수 있게 함)

- (a) 백도어: 정상적인 인증 과정을 거치지 않고 시스템에 몰래 들어갈 수 있는 숨겨진 통로

^{iv} Tamper Resistance: 변조 방지 포장과 물리적 보안 조치를 사용하여 무단 접근이나 변조 시도를 억제

ex) 에폭시 포팅, 변조 방지 씰, 침입 탐지 메커니즘

- (a) 에폭시 포팅: 에폭시로 완전히 감싸 굳혀서 외부에서 분석하거나 변조하기 어렵게 만드는 물리적 보호기법

^v Secure Hardware Design: 암호화 알고리즘, 견고한 인증 메커니즘, 안전한 부팅 프로세스 구현과 같은 안전한 설계 원칙을 초기에 도입

^{vi} Firmware Security: 펌웨어 이미지를 암호화하고 전송 및 설치 시 디지털 서명을 하여 변조와 조작에 대한 보호 층 추가